Room Name: Burp Suite: Repeater

Objective: To understand how Burp Suite Repeater works and learn how to capture, modify, and resend HTTP requests to test web application behavior and identify potential vulnerabilities.

Key Concepts Learned:

- Burp Suite Repeater
- HTTP Request and Response Manipulation
- Sending Requests from Proxy to Repeater
- Manual Request Modification
- Request and Response Analysis
- Repeater Request History
- Pretty, Raw, Hex, and Render Views
- Non-Printable Characters (CRLF)
- Burp Suite Inspector
- HTTP Headers and Cookies
- Query and Body Parameters
- Server Response Analysis
- Error-Based Testing
- SQL Injection (SQLi)
- UNION-Based SQL Injection
- Information Disclosure Through Error Messages

Tools and Features Used:

- **Burp Suite:** A web application security testing platform used to intercept, inspect, modify, and analyze HTTP traffic.
- **Proxy:** Used to intercept browser requests and forward captured requests to Repeater for further testing.
- **Repeater:** Used to manually modify and resend HTTP requests multiple times and compare server responses.
- **Inspector:** Used to view and modify request components through an organized interface, including headers, cookies, query parameters, and body parameters.
- **AttackBox / Lab Machine:** Used to access the testing environment and interact with the vulnerable web application.

Practical Work:

- Explored the Burp Suite Repeater interface and its main sections, including Request List, Request Controls, Request/Response View, Layout Options, Inspector, and Target.
- Captured HTTP requests through Proxy and sent them to Repeater using the **Ctrl + R** shortcut.
- Modified HTTP request headers and resent requests to observe changes in server responses.
- Explored different response views, including Pretty, Raw, Hex, and Render.

- Used the Inspector to examine and modify request attributes, query parameters, cookies, and headers.
- Added a custom `FlagAuthorised: True` header to a request and observed the server's response.
- Tested a numeric product endpoint by changing its input values and observed how invalid or extreme values could trigger a **500 Internal Server Error**.
- Practiced identifying a SQL Injection vulnerability in the `/about/ID` endpoint using a modified request.
- Used a single quotation mark to observe the server's error response and identify information about the underlying SQL query.
- Explored UNION-based SQL Injection to identify database columns and retrieve the CEO's notes from the lab database.
- Completed the practical challenges using Repeater to understand how request manipulation can reveal weaknesses in web applications.

Useful Repeater Actions:

```
# Send a captured request to Repeater
Right-click request → Send to Repeater

# Keyboard shortcut
Ctrl + R

# Send the modified request
Click Send

# Example of adding a custom HTTP header
GET / HTTP/1.1
Host: MACHINE_IP
FlagAuthorised: True

# Example of testing the numeric endpoint
GET /products/3 HTTP/1.1
Host: MACHINE_IP

# Example of checking SQL syntax errors
GET /about/2' HTTP/1.1
Host: MACHINE_IP
```

Important Observations:

- Repeater allows repeated testing of the same request without having to perform the action again in a browser.
- Proxy is useful for capturing HTTP requests, while Repeater is useful for modifying and testing them.
- The Pretty view improves readability, Raw displays the unmodified response, Hex shows byte-level data, and Render displays the page visually.
- Inspector provides an organized way to examine and modify request components.
- The Request Body Parameters section is particularly relevant to POST requests.
- Server error messages can expose internal database queries, table names, and column information.
- A **500 Internal Server Error** may indicate that an application failed to process a request, but it does not independently prove a vulnerability.

- UNION-based SQL Injection can allow an attacker to retrieve information from a database when the application is vulnerable.
- Detailed database errors and insufficient input validation can expose sensitive application information.
- Repeater is useful for manually testing authentication, parameter handling, access control, and other web application security issues.

Room Link: https://tryhackme.com/room/burpsuiterepeater

Status: Complete